DOCUMENTO DE CÁTEDRA N°15

TEMA: CONVERGENCIA IT/OT: DESAFÍOS DE INTEGRACIÓN Y LA INDUSTRIA 4.0

Apertura: Colonial Pipeline — el oleoducto que se apagó solo

En mayo de 2021, el grupo de ransomware DarkSide penetró la red corporativa de Colonial Pipeline, el mayor operador de oleoductos de productos refinados de Estados Unidos, responsable del suministro del 45% del combustible de la costa este norteamericana. El vector de acceso inicial fue una contraseña de VPN comprometida, sin autenticación de múltiple factor. En menos de dos horas, el malware cifró aproximadamente 100 GB de datos en la red IT corporativa.

Lo que sucedió a continuación no fue un ataque a los sistemas OT. Fue una decisión: la dirección de Colonial Pipeline ordenó apagar preventivamente el oleoducto. No porque los PLCs, servidores SCADA ni los sistemas de control de flujo hubieran sido comprometidos. Sino porque nadie en la organización podía garantizar que la red OT estaba suficientemente aislada de la red IT comprometida como para operar con seguridad mientras el adversario mantuviera control de la infraestructura corporativa.

El resultado fue el mayor impacto en infraestructura energética crítica de la historia reciente de Estados Unidos: 5.500 millas de oleoducto paralizado durante seis días, 17 estados declarados en emergencia energética, desabastecimiento de combustible de aviación en aeropuertos del sudeste, y el pago de un rescate de 4,4 millones de dólares en Bitcoin.

Este caso establece la tesis central de este documento: los sistemas OT de Colonial Pipeline no fueron comprometidos. Fueron apagados porque la convergencia IT/OT había creado una dependencia de confianza entre los dos dominios que, una vez rota por el ransomware, hacía imposible operar el OT con certeza, aunque los controladores estuvieran técnicamente intactos. En un entorno perfectamente segmentado, la misma brecha de ransomware habría producido un impacto limitado al dominio IT. El oleoducto habría seguido operando.

La convergencia IT/OT no es solo un vector de propagación de ataques: es una relación de dependencia que puede paralizar procesos físicos críticos sin que ningún sistema de control haya sido atacado directamente.

Ubicación en el Programa: Este Documento N°15 abre la Unidad 4. Las tres unidades previas construyeron el mapa técnico del entorno OT: los componentes de hardware de control (U1), los PLCs, RTUs y HMIs con su lógica de automatización (U2), y los sistemas de supervisión —SCADA, DCS, historian, protocolos industriales y aplicaciones verticales BMS y PACS— con sus vulnerabilidades estructurales (U3). La Unidad 4 retoma ese mapa técnico y lo analiza desde la perspectiva doctrinal: qué significa para la Ciberdefensa que esos mundos converjan y qué establece la normativa de referencia. El Documento N°16 analizará el ecosistema IoT/IIoT como la manifestación más acelerada de la convergencia no controlada. Los Documentos N°17

y N°18 completarán la Unidad con la doctrina de gestión de riesgos OT y el análisis forense de Stuxnet e Industroyer.

OBJETIVOS DE APRENDIZAJE

- Describir el Modelo Purdue de referencia para arquitecturas ICS e identificar los vectores que están erosionando su segmentación en entornos modernos.
- Identificar las tecnologías clave de la Industria 4.0 —digital twin, cloud industrial, edge computing y mantenimiento predictivo— y evaluar cómo cada una modifica la superficie de ataque OT.
- Analizar los principales modos de integración IT/OT y caracterizar el perfil de riesgo de cada uno en términos del Modelo Purdue.
- Aplicar los marcos normativos NIST SP 800-82 Rev. 3 e ISA/IEC 62443 como herramientas de gestión de la convergencia en entornos de infraestructura crítica y de Defensa.
- Diseñar arquitecturas de segmentación IT/OT aplicando los conceptos de Security Zones, Conduits y DMZ OT para romper cadenas de ataque cruzadas.

1. EL MODELO PURDUE Y SU EROSIÓN

1.1. La arquitectura de referencia

El Modelo Purdue —formalmente Purdue Enterprise Reference Architecture (PERA), desarrollado por Theodore Williams en la Universidad Purdue en la década de 1990— es el marco de referencia que durante décadas organizó la separación entre los sistemas industriales y las redes corporativas. Adoptado por el estándar ISA-95 y la guía NIST SP 800-82, estructura el entorno IT/OT en seis niveles funcionales con una premisa de seguridad central: la comunicación entre niveles no adyacentes es una anomalía que debe ser controlada, auditada y justificada operativamente.

Nivel	Denominación	Función principal	Dispositivos típicos	Estado real y riesgo de convergencia
0	Proceso Físico	Monitoreo y control directo de activos físicos	Sensores, actuadores, válvulas, transmisores	Sin conectividad IP nativa. Accesible solo por fieldbus serial sin autenticación. Objetivo final de ataques OT sofisticados.
1	Control Básico	Automatización en tiempo real del proceso	PLCs, RTUs, controladores de campo	Ciclos de vida de 15 a 25 años. Accesible desde Level 2 por protocolos industriales. Comprometerlo equivale a comprometer el proceso físico.

Nivel	Denominación	Función principal	Dispositivos típicos	Estado real y riesgo de convergencia
2	Control Supervisorio	Supervisión local y visualización del proceso	HMIs locales, servidores SCADA, estaciones de ingeniería	Nivel con mayor número de incidentes documentados. SO legacy frecuente. El vector HMI es el más explotado en ataques OT de nivel medio.
3	Operaciones de Planta	Optimización, historización y gestión del proceso	Historian, OPC Server, MES, servidor de acceso remoto	Zona de mayor convergencia práctica. El historian debe leer Level 2 y ser leído por Level 4. Punto de brecha central si no existe DMZ 3.5.
DMZ 3.5	Zona de Transferencia	Control y filtrado de datos entre OT e IT	Firewall industrial, servidor de réplica unidireccional, jump server	Frecuentemente ausente en instalaciones legacy. Su ausencia es el denominador común de los incidentes de mayor impacto: caso Target, caso Colonial Pipeline.
4	Red Corporativa	Gestión del negocio y conectividad IT	ERP, email corporativo, Active Directory, workstations	Dominio IT estándar. Vector de entrada más frecuente para ataques que pivotean hacia OT cuando no existe DMZ 3.5.

La premisa de seguridad del modelo es la distancia jerárquica: cuanto más abajo en la estructura, más crítico el activo y más restringido el acceso. Un Level 4 no debería comunicarse directamente con Level 1. Ningún dispositivo externo debería alcanzar ningún nivel OT sin atravesar los controles de la DMZ 3.5. Esa es la arquitectura. La realidad es distinta.

1.2. Los cinco vectores de erosión del Modelo Purdue

El Modelo Purdue fue diseñado en un contexto donde la conectividad OT era principalmente serial, los sistemas SCADA no contemplaban TCP/IP y el acceso remoto era excepcional y costoso. En el entorno actual, cinco vectores sistémicos están erosionando esa segmentación en instalaciones industriales de todo tipo, incluyendo instalaciones gubernamentales y de Defensa:

Vector de erosión	Mecanismo técnico	Riesgo principal	Contramedida
Cloud industrial	Gateway o edge device en Level 1/2 envía datos de proceso directamente a plataforma cloud	Level 1/2 adquiere conectividad directa a internet. El cloud provider se convierte en actor externo con	Cloud connector ubicado en DMZ 3.5. Flujo estrictamente unidireccional (solo PUSH desde OT hacia

Vector de erosión	Mecanismo técnico	Riesgo principal	Contramedida
	(AWS IoT, Azure IoT Hub), omitiendo la DMZ OT.	acceso a datos del proceso en tiempo real.	la nube). Prohibir subscripciones cloud que envíen comandos hacia OT.
Acceso remoto no segmentado	VPN del contratista termina directamente en Level 3 o en la VLAN de control (Level 2), sin jump server ni filtrado adicional entre la VPN y los controladores.	Las credenciales del contratista son la llave de entrada directa al OT. Vector del caso Target (HVAC) y del caso Colonial Pipeline.	Jump server en DMZ 3.5 con MFA obligatorio, grabación de sesión, acceso con permisos mínimos y revocación automática al finalizar cada intervención.
Historian bidireccional	Servidor historian con dos interfaces de red simultáneas: una en VLAN OT y otra en VLAN IT, actuando como bridge de Capa 3 entre ambos dominios.	Cualquier compromiso del dominio IT puede pivotar al historian y, desde él, al OT. El historian es un puente no controlado entre los dos mundos.	Historian con interfaz única en VLAN OT. Replicación unidireccional a servidor de reporting en DMZ 3.5 que expone solo datos de lectura hacia IT.
Dispositivos IIoT dual-homed	Sensores o controladores IIoT en Level 1/2 con conectividad simultánea al fieldbus de control Y a WiFi o 4G para telemetría independiente.	Level 1 adquiere conectividad no controlada hacia internet. La interfaz WiFi/4G bypasea completamente el firewall perimetral del OT.	Inventariar y eliminar conectividades duales no aprobadas. Si son operativamente necesarias, VLAN dedicada OT con autenticación de certificado y monitoreo de dispositivos asociados.
WiFi en planta sin segmentación	Access points WiFi configurados en la misma VLAN que los dispositivos de control OT, o sin segmentación clara respecto a la red IT corporativa.	Cualquier dispositivo que se asocie al AP obtiene acceso a la red de control desde Level 2, incluyendo dispositivos no autorizados.	WiFi OT en VLAN dedicada y aislada, SSID no visible, autenticación 802.1X con certificados, lista blanca de MACs y monitoreo de nuevas asociaciones.

Nota de Ciberdefensa — ¿Está tu red OT realmente segmentada? El checklist del profesional

El mayor riesgo de convergencia es el invisible: el que nadie documentó, el que se creó por conveniencia operativa y nunca se revisó. Un profesional de Ciberdefensa ante cualquier instalación debe verificar cinco condiciones antes de asumir que la segmentación Purdue está vigente:

Condición 1 — Flujo de red: ¿puede un paquete originado en Level 4 alcanzar Level 1 o Level 2 sin atravesar al menos un firewall con política de denegación por defecto? Si la respuesta es sí o no se sabe, la segmentación no existe.

Condición 2 — Acceso remoto: ¿cómo acceden los contratistas de mantenimiento a los controladores? ¿La VPN termina en Level 3 con jump server, o tienen acceso directo a la VLAN de control? El caso Target y el caso Colonial Pipeline comparten un acceso de terceros sin segmentación adecuada como vector inicial.

Condición 3 — El historian: ¿el servidor historian tiene interfaces de red en la zona OT Y en la zona IT simultáneamente? Si es así, es un bridge potencial entre las dos redes, independientemente de las políticas del sistema operativo.

Condición 4 — Dispositivos IIoT: ¿hay dispositivos en Level 1 o Level 2 con conectividad WiFi o 4G además de su conexión de fieldbus? Un sensor con módulo 4G tiene dos interfaces: una en Level 1 y otra directamente en internet.

Condición 5 — Flujos cloud: ¿hay algún gateway o edge device que envía datos de proceso directamente a una plataforma cloud sin pasar por el historian segmentado en la DMZ? Ese gateway es un punto de convergencia Level 1/Internet sin controles intermedios.

2. LA INDUSTRIA 4.0 Y LA SUPERFICIE DE ATAQUE OT

2.1. Las cuatro tecnologías disruptivas y su impacto en la segmentación

La Industria 4.0 —el conjunto de tecnologías y paradigmas de digitalización industrial articulado inicialmente en la estrategia alemana Industrie 4.0 de 2011— introduce cuatro tecnologías que transforman la economía de la conectividad OT. Cada una genera un beneficio operativo real y, simultáneamente, introduce un nuevo vector de convergencia que debe ser gestionado explícitamente:

Tecnología I4.0	Descripción	Requisito de conectividad OT	Riesgo para la segmentación
Digital Twin	Réplica digital en tiempo real de un proceso físico que permite simular, analizar y optimizar sin intervenir en el proceso real.	Flujo continuo de datos de estado desde sensores de Level 0/1 hacia el modelo computacional, ubicado en IT o en cloud.	Requiere un canal permanente desde Level 1/2 hacia IT o cloud. Si no es estrictamente unidireccional y segmentado en DMZ, crea un vector bidireccional.
Cloud Industrial	Plataformas SaaS para analítica de proceso a escala: Siemens MindSphere, AWS IoT, Azure Industrial IoT, GE Predix.	Datos de proceso de Level 1/2 viajan periódicamente o en tiempo real a datacenter externo del cloud provider.	La superficie de ataque incluye el cloud provider y sus portales web. Un compromiso del tenant cloud es un compromiso de los datos del proceso.
Edge Computing	Procesamiento distribuido en dispositivos en Level 1/2, cerca de los activos físicos, para reducir latencia y ancho de banda hacia sistemas centrales.	Los edge devices tienen interfaces simultáneas en red OT y en red IP/Internet para recibir actualizaciones y enviar resultados.	Edge devices son nodos de convergencia en el nivel más crítico del OT. Comprometidos, el adversario está dentro del Level 1/2 con capacidad de interacción con el proceso.

Tecnología I4.0	Descripción	Requisito de conectividad OT	Riesgo para la segmentación
Mantenimiento predictivo	Análisis de vibración, temperatura y corriente de activos críticos para predecir fallos antes de que ocurran.	Sensores IIoT adicionales en activos críticos, gateway de datos hacia plataforma de análisis, acceso remoto del especialista analista.	Tres vectores simultáneos: sensores IIoT en Level 1 (potencialmente dual-homed), gateway de convergencia, y canal de acceso remoto del proveedor.

2.2. La presión operativa frente a la postura de seguridad

Las tecnologías I4.0 tienen un ROI demostrable: reducción del downtime no planificado del 30 al 50%, optimización del consumo energético, y capacidad de respuesta ante fallos que los sistemas de control tradicionales no pueden proveer. Esos beneficios generan una presión organizacional que frecuentemente supera los controles de seguridad. El ingeniero de planta que implementa el mantenimiento predictivo no está tomando una decisión de ciberseguridad: está tomando una decisión de eficiencia operativa, y la ciberseguridad es una externalidad no incluida en su análisis.

El resultado es la proliferación de lo que la industria denomina shadow OT: integraciones de conectividad implementadas fuera del proceso de gestión de riesgos de seguridad, no documentadas, no monitoreadas y frecuentemente desconocidas por el equipo de seguridad. Estudios de Claroty (2023) indican que el 58% de los dispositivos OT conectados a internet en organizaciones industriales no fueron incluidos en el proceso formal de aprobación de seguridad antes de su conexión. El shadow OT no es un fenómeno excepcional: es la norma en instalaciones que han adoptado tecnologías I4.0 sin un marco de gobernanza IT/OT maduro.

Nota de Ciberdefensa — La Industria 4.0 en instalaciones militares argentinas: modernización y seguridad operacional

Las instalaciones militares y gubernamentales argentinas no son ajenas a la presión de la Industria 4.0. Tres vectores de adopción son especialmente relevantes en el contexto de la Defensa Nacional:

Mantenimiento predictivo en sistemas críticos: la adopción de sensores IIoT en motores, generadores y sistemas de refrigeración. El proveedor de la solución típicamente requiere acceso remoto periódico para calibrar modelos. Si ese acceso no está correctamente segmentado, es un vector de ingreso a la red de sistemas críticos.

Medición inteligente de energía: los smart meters instalados en instalaciones militares reportan consumo en tiempo real a plataformas de gestión energética. Estos dispositivos están en Level 1 del Modelo Purdue y tienen conectividad IP. El patrón de consumo energético de una instalación militar tiene valor de inteligencia para un adversario estatal.

Sistemas BMS cloud-connected: los nuevos sistemas de gestión de edificios con capacidades cloud permiten monitoreo remoto del consumo y estado de equipos. Un BMS cloud-connected en una instalación de Comando y Control es exactamente el vector del caso Target, con la diferencia de que el impacto no es la pérdida de datos de tarjetas, sino la interrupción de las capacidades de mando.

La doctrina operacional de Ciberdefensa debe establecer que ninguna integración IT/OT en instalaciones críticas se implemente sin una evaluación formal de riesgos que incluya el perfil de ataque habilitado por la nueva conectividad. La modernización tecnológica y la seguridad

operacional no son objetivos en conflicto, pero requieren una gestión explícita de la convergencia.

3. MODOS DE INTEGRACIÓN IT/OT Y SU PERFIL DE RIESGO

La convergencia IT/OT no es un fenómeno binario (conectado vs. no conectado). Es un continuo de modos de integración con perfiles de riesgo muy distintos que dependen de dónde termina la conexión en la jerarquía Purdue, qué flujos de datos son bidireccionales y qué controles intermedian esa relación. La siguiente tabla sistematiza los seis modos más frecuentes en instalaciones industriales y gubernamentales:

Modo de integración	Descripción técnica	Perfil de riesgo	Contramedida recomendada
Historian con acceso directo a IT	El historian en Level 3 tiene conectividad directa hacia Level 4 sin servidor intermediario en DMZ 3.5. Cualquier workstation IT puede consultar el historian directamente.	ALTO. Compromiso del dominio IT puede pivotar al historian y desde él al OT. Modo más frecuente en instalaciones legacy.	Historian con única interfaz en VLAN OT. Servidor de reporting separado en DMZ que replica datos de solo lectura hacia IT. Ningún flujo de escritura desde IT.
VPN de contratista directa	El proveedor tiene una VPN que termina directamente en Level 3 o en la VLAN de control del Level 2, sin jump server ni filtrado adicional entre la VPN y los controladores.	ALTO. Las credenciales del contratista son equivalentes a credenciales de acceso al OT. Vector del caso Target y del caso Colonial Pipeline.	Jump server en DMZ 3.5 con MFA obligatorio. Sesiones grabadas. Acceso limitado al subsistema de responsabilidad del contratista. Revocación de acceso tras cada intervención. Credenciales individuales, nunca compartidas.
Gateway IIoT a cloud	Edge device o gateway en Level 1/2 envía datos de proceso directamente a plataforma cloud mediante MQTT, REST API o similar, sin pasar por la DMZ OT.	ALTO. El cloud provider es un tercero fuera del perímetro de control. Compromiso del broker cloud otorga visibilidad en tiempo real del proceso.	Cloud connector en DMZ 3.5. Protocolo estrictamente unidireccional (solo lectura desde OT). El sistema cloud nunca puede enviar comandos hacia OT. TLS mutuo con certificados por dispositivo.
Acceso web a HMI	La HMI de Level 2 tiene interfaz web accesible desde la red IT corporativa para monitoreo remoto, sin autenticación adicional	ALTO. Las HMIs con acceso web son vectores documentados de acceso OT. Una workstation IT comprometida es	HMI sin acceso web expuesto a la red IT. Si es operativamente imprescindible, solo desde jump server en

Modo de integración	Descripción técnica	Perfil de riesgo	Contramedida recomendada
	más allá de usuario/contraseña.	una ventana abierta al sistema de control.	DMZ 3.5 con MFA y lista blanca de IPs de origen.
Módulo celular en RTU de campo	RTU en ubicación remota tiene un módulo de comunicación celular 4G para telemetría o acceso de emergencia que no pasa por el firewall de la instalación central.	ALTO. El módem crea un túnel directo entre Level 1 y la red del operador celular, sin DMZ ni firewall corporativo. Accesible directamente desde internet.	APN privado del operador celular. VPN sobre el canal celular con terminación en DMZ 3.5. Nunca IP pública directa de la RTU. Inventario de todos los módulos celulares en campo.
MQTT broker corporativo en cloud	Los dispositivos de campo publican datos a un broker MQTT gestionado por la organización en su tenant cloud. Los sistemas IT subscriben al broker para leer datos.	MEDIO. El broker actúa como intermediario. El riesgo aumenta si acepta publicaciones bidireccionales o si la autenticación es débil.	Tópicos MQTT de solo lectura desde OT. Autenticación con certificados TLS mutuos por dispositivo. Broker en segmento DMZ. Auditoría de qué sistemas tienen permiso de escritura hacia tópicos de control.

Nota de Ciberdefensa — Colonial Pipeline revisitado: la arquitectura que habría cambiado la decisión

La decisión de apagar el oleoducto en el caso Colonial Pipeline fue racional dada la información disponible en el momento: la red IT estaba comprometida y nadie podía garantizar la integridad del OT. Pero esa incertidumbre era, en sí misma, un síntoma de un problema de arquitectura.

En una instalación con segmentación estricta conforme al Modelo Purdue, la misma brecha habría provisto la información necesaria para una decisión diferente: (1) los logs del firewall de la DMZ OT habrían mostrado si el tráfico del ransomware intentó cruzar al Level 3; (2) el IDS de la red OT habría registrado cualquier tráfico anómalo en protocolos de control; (3) la ausencia de conectividad directa entre la red IT y los controladores habría sido verificable técnicamente en minutos.

La lección doctrinal de Colonial Pipeline no es solo «segmenta tu red OT». Es «diseña tu arquitectura de segmentación de modo que puedas tomar decisiones operativas informadas bajo presión, en tiempo real, con certeza técnica». Una arquitectura que no puede responder la pregunta «¿está comprometido mi OT?» durante un incidente IT activo es una arquitectura que forzará el apagado preventivo del proceso físico.

4. MARCOS NORMATIVOS PARA LA GESTIÓN DE LA CONVERGENCIA

4.1. NIST SP 800-82 Revisión 3 (2023)

El NIST SP 800-82 —Guide to Operational Technology (OT) Security— es la guía de referencia para la seguridad de sistemas de control industrial publicada por el National Institute of Standards and Technology de Estados Unidos. La Revisión 3, publicada en

septiembre de 2023, actualiza sustancialmente la Revisión 2 (2015) incorporando el ecosistema IIoT, la nube industrial, el edge computing y los principios de arquitecturas Zero Trust aplicados a OT. La guía organiza los controles de seguridad OT alrededor de las cinco funciones del NIST Cybersecurity Framework (CSF) 2.0:

Función CSF	Objetivo en OT	Control OT específico	Ejemplo de implementación
Identify (Identificar)	Conocer el inventario completo de activos OT, sus interconexiones y su criticidad para el proceso	Mapa de activos OT con nivel Purdue asignado, protocolos activos, conectividades externas y propietario responsable de cada activo	Herramienta de descubrimiento pasivo de red OT (Nozomi, Claroty, Dragos) para inventario sin riesgo de disrupción. Documentación de todos los modos de integración IT/OT.
Protect (Proteger)	Implementar salvaguardas que limiten o prevengan el impacto de un incidente de ciberseguridad en el OT	Segmentación por VLANs con firewall de denegación por defecto, control de acceso privilegiado, hardening de dispositivos OT	DMZ OT implementada (Level 3.5). Jump server con MFA para todo acceso remoto. Deshabilitar servicios y puertos no utilizados en PLCs y HMIs. Actualizaciones de firmware en ventanas de mantenimiento programadas.
Detect (Detectar)	Identificar oportunamente la ocurrencia de eventos de ciberseguridad en la red OT	IDS pasivo específico de protocolos industriales, baseline de tráfico normal, alertas ante comandos atípicos	SIEM con ingesta de logs OT e IT correlacionados. Alertas ante comandos de escritura inusuales (Modbus Write, BACnet WriteProperty). Monitoreo de nuevas conexiones en Level 1/2.
Respond (Responder)	Contener el impacto de un incidente detectado sin detener innecesariamente el proceso físico	Playbooks de respuesta a incidentes OT diferenciados de los playbooks IT, procedimientos de segmentación de emergencia	Procedimiento de aislamiento de VLAN OT sin apagado del proceso. Roles definidos: quién puede desconectar qué y bajo qué condición de autorización. Contactos de notificación a CIRT-Defensa.
Recover (Recuperar)	Restaurar las capacidades del sistema OT afectadas y retornar a operación normal verificada	Respaldos periódicos de configuración de PLCs, RTUs y HMIs. Procedimiento de restauración documentado y ensayado	Backups offline cifrados de configuración de todos los controladores. Procedimiento de restauración desde cero ensayado al menos una vez al año. Plan de operación manual documentado para el período de recuperación.

La versión 2.0 del NIST CSF (2024) agrega una sexta función: Govern (Gobernar), que establece el contexto organizacional, los roles y las responsabilidades. En entornos OT de Defensa, la función Govern es especialmente relevante porque define quién es responsable de la seguridad OT, una zona de disputa frecuente entre el equipo IT, los ingenieros de operaciones y las cadenas de comando militares.

4.2. ISA/IEC 62443: el estándar de referencia para entornos OT

El estándar ISA/IEC 62443 —desarrollado por el comité ISA99 de la International Society of Automation y adoptado por la IEC— es el marco normativo más completo para la seguridad de sistemas de automatización e infraestructura crítica. Introduce dos conceptos clave que el profesional de Ciberdefensa debe dominar:

Security Zones: agrupación lógica de activos OT con perfil de riesgo similar y requisitos de seguridad comunes. Todos los activos de una zona comparten las mismas políticas de control de acceso. Los criterios para definir zonas incluyen función similar, misma criticidad del proceso y mismo nivel de confianza requerido para el acceso.

Conduits: canal de comunicación controlado entre dos Security Zones. No es simplemente un cable o una conexión de red: es el conjunto de controles —firewall, IDS, filtrado de protocolo industrial— que gobiernan qué tráfico puede transitar entre zonas y en qué dirección. Un conduit entre la zona OT y la zona IT es lo que hace que el historian segmentado sea diferente del historian bidireccional del vector de erosión de la Sección 1.

SL	Descripción	Tipo de adversario resistido	Ejemplo de instalación aplicable
SL 1	Protección ante adversarios no dirigidos (casual, oportunista, sin conocimiento de OT)	Malware genérico, errores de configuración accidentales, usuarios internos sin conocimiento técnico de OT. El adversario no planifica el ataque.	Plantas de manufactura no crítica, edificios comerciales, sistemas de gestión energética en instalaciones de bajo impacto.
SL 2	Protección ante adversarios dirigidos con baja sofisticación y recursos limitados	Hacktivistas, insiders técnicos con conocimiento básico de OT, ataques dirigidos de complejidad media. El adversario planifica el ataque con recursos limitados.	Plantas industriales con consecuencias económicas significativas. Infraestructura pública. Nivel mínimo recomendado para infraestructura crítica civil no militar.
SL 3	Protección ante adversarios con recursos significativos y conocimiento específico de OT (APT)	Grupos de ciberespionaje patrocinados, actores APT con conocimiento de protocolos OT, ataques de sabotaje industrial deliberado. Capacidad de desarrollo de malware OT específico.	Infraestructura crítica nacional: redes eléctricas, plantas de agua, refinerías. Nivel objetivo mínimo para instalaciones militares que soportan misiones críticas.

SL	Descripción	Tipo de adversario resistido	Ejemplo de instalación aplicable
SL 4	Protección ante actores estatales con capacidades avanzadas, recursos ilimitados y potencial acceso físico a la instalación	Ataques tipo Stuxnet: cadena de ataque física y cibernética coordinada, conocimiento específico de la instalación objetivo, recursos de inteligencia de estado. Capacidad de explotar vulnerabilidades de día cero en plataformas OT específicas.	Infraestructura crítica de nivel estratégico nacional: instalaciones nucleares, sistemas de comando y control militar, sistemas de armas embarcados.

5. ACTIVIDADES DE VERIFICACIÓN Y ANÁLISIS

1. Análisis del caso Colonial Pipeline — la arquitectura que determinó la decisión operativa

En mayo de 2021, Colonial Pipeline apagó preventivamente su infraestructura OT ante un ataque de ransomware que comprometió exclusivamente la red IT corporativa. Analice el caso desde la perspectiva de la arquitectura de convergencia IT/OT estudiada en este documento.

(a) Identifique el modo de integración IT/OT que permitió que la brecha en la red IT generara incertidumbre sobre el estado del OT. Relacione su respuesta con la Tabla de Modos de Integración de la Sección 3 e identifique el nivel del Modelo Purdue donde se encontraba el punto de indefinición.

(b) Diseñe la arquitectura de segmentación alternativa que habría permitido operar el oleoducto durante el incidente IT con certeza razonable de que el OT no estaba comprometido. Describa las VLANs necesarias, el papel de la DMZ OT, los controles en el jump server y el mecanismo de monitoreo que habría provisto esa certeza técnica.

(c) Argumente, desde la perspectiva de la tríada AIC, por qué la decisión de apagado fue racional dada la arquitectura existente, y en qué condiciones arquitectónicas específicas la misma decisión habría cambiado.

2. Auditoría de erosión del Modelo Purdue en una planta de tratamiento de agua

Se le presenta la arquitectura de red de una planta de tratamiento de agua con las siguientes características: (1) Los PLCs del Level 1 envían datos vía Modbus TCP a un servidor historian Linux en Level 3 que tiene dos interfaces de red simultáneas: una en la VLAN OT y otra en la VLAN IT corporativa. (2) El proveedor del sistema de dosificación química accede al PLC correspondiente mediante una VPN corporativa que termina en Level 4. (3) El servidor BMS del edificio administrativo está en la misma VLAN que el historian.

(a) Identifique cuántos y cuáles vectores de erosión del Modelo Purdue están presentes en esta arquitectura, con referencia explícita a la Tabla 2 de la Sección 1.

(b) Trace la cadena de ataque más corta posible desde un adversario externo sin acceso físico hasta los PLCs del Level 1, indicando en cada paso qué mecanismo de convergencia permite el avance.

(c) Proponga las correcciones mínimas necesarias para que la arquitectura cumpla con los principios del NIST SP 800-82 Rev. 3. Para cada corrección, indique el vector de erosión que elimina y la función del NIST CSF que implementa.

3. Evaluación de riesgo I4.0 — mantenimiento predictivo en instalación militar

Una instalación militar quiere implementar mantenimiento predictivo en sus generadores de emergencia usando sensores IIoT de vibración y temperatura del proveedor X, que envían datos a una plataforma cloud propietaria mediante MQTT sobre TLS 1.3. El proveedor requiere acceso remoto periódico para calibrar los modelos predictivos. Los generadores son la única fuente de energía de la sala de comunicaciones durante cortes de red.

(a) Identifique el modo de integración IT/OT que esta solución representa según la Tabla de la Sección 3. Justifique el perfil de riesgo considerando la criticidad de los generadores en el contexto de la misión de la instalación.

(b) Aplique el modelo de Security Level del ISA/IEC 62443 para determinar qué SL debería tener la zona donde se instalan los sensores y el gateway. Justifique la clasificación en términos del tipo de adversario que la instalación podría enfrentar.

(c) Diseñe los controles mínimos de integración que harían aceptable este riesgo: ubicación del gateway en el Modelo Purdue, mecanismo de acceso remoto del proveedor, protocolo de autenticación de los sensores, y qué monitoreo se implementaría para detectar comportamiento anómalo.

4. Caso integrador — arquitectura IT/OT segura para gestión energética en base naval

El oficial de logística de una base naval propone implementar un sistema de gestión energética que integre: (1) medidores de energía inteligentes en cada edificio, conectados por Modbus TCP a un concentrador de telemetría; (2) un servidor de gestión energética en la red IT corporativa que recibe datos del concentrador cada 15 minutos; (3) un dashboard web accesible para el oficial desde la red IT para visualizar el consumo en tiempo real.

(a) Identifique todos los puntos de convergencia IT/OT en la arquitectura propuesta y clasífíquelos según el Modelo Purdue, indicando qué niveles quedan conectados en cada punto y qué vector de erosión de la Sección 1 representa cada uno.

(b) Diseñe la arquitectura revisada que implementa la misma funcionalidad cumpliendo con los principios de segmentación estricta: enumere las VLANs necesarias, la ubicación del concentrador y el servidor de reporting en la DMZ, y los flujos de datos permitidos indicando su dirección (solo lectura, solo escritura, bidireccional).

(c) Aplique el modelo de Zones y Conduits del ISA/IEC 62443 a la arquitectura revisada: defina las Security Zones, describa los Conduits entre ellas con sus controles, y asigne Security Levels a cada zona justificando la elección según la criticidad de los activos.

6. GLOSARIO MÍNIMO

Término	Definición
Conduit (ISA/IEC 62443)	Canal de comunicación controlado entre dos Security Zones. Comprende el conjunto de controles —firewall, IDS, filtrado de protocolo industrial— que gobiernan qué tráfico puede transitar entre zonas y en qué dirección.
Convergencia IT/OT	La integración técnica de los sistemas de información corporativos (IT) con los sistemas de control industrial y de infraestructura (OT), creando dependencias bidireccionales entre dominios con culturas de seguridad, ciclos de vida y prioridades operativas distintas.
Digital Twin	Réplica digital en tiempo real de un proceso o activo físico. Su implementación introduce un canal de conectividad permanente desde Level 1/2 hacia sistemas IT o cloud que debe ser gestionado como vector de convergencia.
DMZ OT	Zona desmilitarizada para entornos OT (Nivel 3.5 del Modelo Purdue). Zona de transferencia controlada de datos entre la red OT (Niveles 0-3) y la red IT corporativa (Nivel 4). Contiene el jump server, el servidor de réplica del historian y el firewall industrial.
Edge Computing	Paradigma de procesamiento distribuido en dispositivos ubicados en Level 1/2, cerca de los activos físicos. Los edge devices son nodos de convergencia con interfaces simultáneas en la red OT y en redes IP externas.
Industria 4.0	Conjunto de tecnologías y paradigmas de digitalización industrial —cloud industrial, digital twin, IIoT, edge computing— que transforman la manufactura e infraestructura mediante integración masiva de conectividad, con impacto directo en la superficie de ataque OT.
ISA/IEC 62443	Familia de estándares internacionales para la seguridad de sistemas de automatización e infraestructura crítica, desarrollados por ISA99. Define Security Levels (SL1-SL4), Security Zones y Conduits como modelo de segmentación y protección de entornos OT.
Modelo Purdue (PERA)	Purdue Enterprise Reference Architecture. Marco de referencia para arquitecturas de sistemas industriales que organiza los componentes en niveles jerárquicos (0 a 4, más DMZ 3.5) estableciendo que la comunicación entre niveles no adyacentes debe ser controlada y auditada.
NIST SP 800-82 Rev. 3	Guide to Operational Technology (OT) Security publicada por el NIST en 2023. Actualiza la Rev. 2 (2015) incorporando IIoT, cloud industrial, edge computing y principios Zero Trust. Marco de referencia para la gestión de la seguridad OT conforme al NIST CSF 2.0.
Security Level (SL)	Nivel de protección requerido para una Security Zone en el marco ISA/IEC 62443, expresado en cuatro niveles (SL1 a SL4) según el tipo de adversario y las capacidades de ataque que la zona debe resistir.
Security Zone	Concepto del ISA/IEC 62443. Agrupación lógica de activos OT con perfil de riesgo similar y requisitos de seguridad comunes. Todos los activos de una zona comparten las mismas políticas de control de acceso.

Término	Definición
Shadow OT	Dispositivos o integraciones de conectividad OT implementados fuera del proceso formal de gestión de riesgos de seguridad, no documentados en el inventario de activos y frecuentemente desconocidos por el equipo de ciberseguridad de la organización.

REFERENCIAS BIBLIOGRÁFICAS

Stouffer, K., et al. (2023). Guide to Operational Technology (OT) Security (NIST SP 800-82 Revision 3). NIST. Capítulo 3: ICS Risk Management; Sección 5: Recommended Security Practices.

International Society of Automation. (2018). ISA/IEC 62443-3-2: Security Risk Assessment for System Design. ISA/IEC.

International Society of Automation. (2013). ISA/IEC 62443-3-3: System Security Requirements and Security Levels. ISA/IEC.

Knapp, E. D., & Langill, J. T. (2015). Industrial Network Security (2da ed.). Syngress. Capítulo 1: The Convergence of IT and ICS; Capítulo 5: Industrial Firewalls and Zones.

CISA. (2021). Colonial Pipeline Cyberattack — Analysis and Recommendations. Cybersecurity and Infrastructure Security Agency.

Claroty. (2023). Biannual ICS Risk & Vulnerability Report. Claroty Research. Sección: IT/OT Convergence Attack Patterns.

Dragos. (2023). ICS/OT Cybersecurity Year in Review. Dragos Inc.

Cátedra Tecnología Operativa (2026). Documentos de Cátedra N°9 al N°14 (Unidades 2 y 3). FADENA.